

Web Attack Risk Prediction

Makine Öğrenmesi ve Açıklanabilir Yapay Zeka ile
Web Saldırı Tespiti ve KVKK Bazlı Maliyet/Fayda Analizi

YÖNETİCİ ÖZETİ RAPORU

1. Problem Tanımı

Web uygulamalarına yönelik siber saldırılar (SQL Injection, XSS, Path Traversal vb.) işletmeler için ciddi finansal ve yasal riskler oluşturmaktadır. Türkiye'de KVKK (6698 sayılı Kanun) kapsamında veri güvenliği ihlalleri 2025 yılı itibarıyla 13.620.402 TL'ye kadar idari para cezası ile sonuçlanabilmektedir.

Bu projede, bir e-ticaret web uygulamasına gelen 61.065 HTTP request analiz edilerek makine öğrenmesi tabanlı saldırı tespit sistemi geliştirilmiş, modelin işletmeye sağlayacağı finansal değer KVKK mevzuatı çerçevesinde kanıtlanmıştır.

Metrik	Değer
Toplam Veri Boyutu	61.065 HTTP request
Veri Kaynağı Sayısı	4 farklı kaynak
En İyi Model	XGBoost (F1=0.9321, AUC=0.9919)
Hiperparametre Optimizasyonu	GridSearchCV (learning_rate=0.2, max_depth=8)
Optimal Threshold	0.05
Net Tasarruf	221.047.839 TL
ROI	%10.551

2. Veri Kaynakları ve Harmanlama

Projede 4 farklı veri kaynağı anlamlı şekilde birleştirilmiştir:

Kaynak	Tür	Boyut	Harmanlama Rolü
CSIC 2010 HTTP	Kaggle CSV	61.065	Ana veri seti: normal ve saldırı HTTP request'leri
Web App Payloads	Kaggle JSONL	455	Saldırı imzaları + regex pattern üretimi
Foospidy Payloads	GitHub	28.569	Kapsamlı saldırı pattern koleksiyonu
Türkiye KVKK	Sentetik	250	KVKK cezaları + maliyet mapping

Harmanlama: Payload koleksiyonlarından (Kaynak 2+3) regex pattern'leri üretilmiş, CSIC request'leri (Kaynak 1) bu pattern'lerle eşleştirilmiş ve tespit edilen saldırı türüne göre KVKK maliyet bilgisi (Kaynak 4) merge edilmiştir.

3. Üretilen Yeni Özellikler (Feature Engineering)

HTTP request'lerden siber güvenlik domain bilgisine dayalı 12 yeni feature türetilmiştir:

- request_length, url_length, content_length: Request boyut metrikleri
- special_char_count, digit_count: Saldırı syntax göstergeleri
- entropy_score: Shannon entropy — yüksek entropi obfuscated payload göstergesi
- encoded_char_ratio: URL encoding oranı — WAF bypass tespiti
- uppercase_ratio: Encoding manipülasyonu göstergesi
- parameter_count, url_depth, is_post, is_put: Yapısal HTTP özellikleri

4. Model Çalışması ve Sonuçlar

Random Forest ve XGBoost modelleri GridSearchCV ile optimize edilmiş, 5-fold Stratified CV ile değerlendirilmiştir:

Model	Accuracy	F1 Score	Precision	AUC-ROC
Random Forest	0.9390	0.9275	0.90	0.9913
XGBoost (Optimize)	0.9433	0.9321	0.91	0.9919

5. Açıklanabilir Yapay Zeka (SHAP) Bulguları

Model kararları SHAP ile hem global hem bireysel düzeyde açıklanmıştır.

Global Bulgular:

- encoded_char_ratio ve request_length en yüksek SHAP etkisine sahip
- Yüksek entropy → saldırı olasılığı artıyor
- uppercase_ratio obfuscation tespitinde kritik rol oynuyor

Bireysel Tahmin Açıklaması (Local Explanation):

Bir saldırı olarak sınıflandırılan örnek request için:

- encoded_char_ratio: 0.0081 → SHAP: +0.1018 (↑ Saldırı)
- special_char_count: 5.0 → SHAP: +0.0981 (↑ Saldırı)
- entropy_score: 4.90 → SHAP: +0.0600 (↑ Saldırı)

SHAP sonuçları siber güvenlik domain bilgisiyle tam tutarlıdır.

6. KVKK Bazlı Maliyet/Fayda Simülasyonu

6.1 Maliyet Matrisi (KVKK Veritabanından Türetilmiş)

Senaryo	Maliyet	Türetim Yöntemi
False Positive	150 TL	Normal kullanıcı bloklanması + destek maliyeti
False Negative	43.677 TL	Ort. olay maliyeti (8.735.389 TL) × ihlale dönüşme olasılığı (%0.5) = Beklenen Değer
True Positive	-500 TL	Saldırı engellendi → potansiyel KVKK cezasından tasarruf

6.2 Threshold Optimizasyonu

- Default threshold (0.50): Toplam maliyet 9.088.347 TL
- Optimal threshold (0.05): Toplam maliyet -2.095.038 TL (net kar)
- Threshold optimizasyonu ile ek 11.183.385 TL tasarruf sağlanmıştır

Bu, standart %50 eşikinin neden yetersiz olduğunun kanıtıdır.

6.3 Senaryo Karşılaştırması ve ROI

Senaryo	Toplam Maliyet	Açıklama
Model Yok	218.952.801 TL	Tüm saldırılar kaçır
Default (t=0.50)	9.088.347 TL	Standart eşik
ML Model (t=0.05)	-2.095.038 TL	Optimal eşik

Net Tasarruf	221.047.839 TL
ROI (Yatırım Getirisi)	%10.551

7. Sonuç ve Öneriler

Bu proje, web saldırı tespitinde makine öğrenmesinin teknik, finansal ve yasal değer üretebileceğini göstermiştir.

Yapılanlar:

- 4 farklı veri kaynağı başarıyla harmanlanmıştır
- 12 iş mantığına dayalı feature türetilmiş, data leakage önlenmiştir
- GridSearchCV ile hiperparametre optimizasyonu yapılmıştır
- XGBoost modeli %94.33 doğruluk ve 0.9919 AUC-ROC ile saldırı tespit etmiştir
- FN maliyeti KVKK veritabanından Beklenen Değer yöntemiyle türetilmiştir (keyfi değil)
- KVKK bazlı simülasyonla 221M TL net tasarruf ve %10.551 ROI kanıtlanmıştır
- SHAP ile model kararları hem global hem bireysel düzeyde açıklanmıştır

Öneriler:

- Üretim ortamında threshold=0.05 ile deploy edilmesi önerilir
- Model, WAF önüne ek bir katman olarak entegre edilebilir
- KVKK uyum süreçlerinde ML tabanlı IDS kullanımı gösterilebilir
- Modelin periyodik olarak yeni payload veritabanlarıyla güncellenmesi önerilir

YBS 4. Sınıf — Python ile Veri Bilimi Dönem Sonu Projesi

Kaynaklar: KVKK Madde 18 (2025 güncel tutarlar), IBM Cost of Data Breach Report 2024, OWASP Top 10 2021